# Matrice d’applicabilité NIS2

Olivier HIMBLOT • ÉnergieAlp • 15 octobre 2026 • Version 1 documentaire

Compétence : Participer à l’élaboration et à la mise en œuvre de la politique de sécurité.

Critère : produire une matrice d’applicabilité NIS2 article par article, reliant les obligations aux configurations techniques, et tenir un registre des actifs critiques et des procédures de gestion des sous-traitants.

| Élément évalué | Pièce présentée | Portée de la preuve |
|---|---|---|
| Applicabilité article par article | Examen des articles 1 à 46, puis contrôles détaillés | Raisonnement documentaire, exclusions et réserves explicites |
| Lien obligation / configuration | Contrôles CT-01 à CT-16 : cible, test et preuve attendue | Conception proposée ; aucune configuration réelle exportée |
| Actifs critiques | Registre EA-01 à EA-05 et justification C/I/D/T | V0 du scénario ; inventaire existant non fourni, validation métier attendue |
| Sous-traitants | Registre ST-01 à ST-03 ; procédures PR-ST-01 à PR-ST-04 | Procédures rédigées pour l’exercice ; application non attestée |

Périmètre : entreprise fictive de distribution d’électricité, environ 650 salariés, 280 000 clients, 30 M€ de chiffre d’affaires 2025. Systèmes : SCADA, compteurs communicants, CRM/facturation, analytics et VPN. Le SCADA est traité comme un actif, sans étude technique industrielle.

Établi dans le scénario : VPN sans MFA, cloud sans contrat ni analyse de risque formalisée, registre incomplet et accès prestataires sans revue périodique documentée. Non établi : conformité réelle, résultat de simulateur, statut OIV, journaux complets, sauvegardes ou contrôles effectivement exécutés.

Lecture : A = retenu dans l’hypothèse EE ; C = conditionnel, à confirmer ; H = cadre institutionnel ou juridique sans configuration directement déductible ; X = hors activité décrite. Ces codes qualifient l’applicabilité, jamais le niveau de conformité.

# 1. Qualification et règles de décision

| Point | Fait / raisonnement | Décision et réserve |
|---|---|---|
| Activité — annexe I | Gestionnaire de réseau de distribution d’électricité : type d’entité du secteur énergie. | Retenu dans le champ sectoriel. |
| Taille — art. 2 et 3 | Environ 650 salariés : dépassement du plafond d’effectif des moyennes entreprises ; 30 M€ de CA n’exclut pas ce constat. | EE proposée selon art. 3 §1 a ; confirmer effectif de référence, périmètre juridique et groupe. |
| Qualification | Le dossier laisse volontairement la qualification ouverte. Aucun simulateur n’a été exécuté. | Conclusion documentaire proposée, sans désignation officielle. OIV à déterminer séparément. |
| Directive / droit français | La directive sert de source européenne. La page ANSSI présente ReCyF comme support de préparation ; ce document ne reconstitue pas la transposition française. | Vérifier textes nationaux publiés, calendrier, autorité et canaux avant usage opérationnel. Aucun numéro de loi française inventé. |
| Responsabilités connues | DSI : CRM, VPN, analytics. Responsable Production : supervision. RSSI : seul habilité à valider une dérogation de sécurité. | Les autres rôles et délais proposés ci-après doivent être approuvés. Une dérogation ne supprime pas une obligation légale. |
| Disponibilité | Supervision et SI clientèle disponibles en continu ; changements en fenêtres validées, nuit/hors pics sauf urgence avérée. | Avant changement : essai, critères de réussite, retour arrière et validation Production/DSI selon périmètre. |

Méthode : fait du dossier → article et condition d’application → objectif de sécurité → configuration cible proposée → test → preuve → décision et responsable. Une absence dans le dossier signifie « non documenté », sauf lorsque le dossier affirme expressément un écart.

Les propositions techniques ne sont pas des prescriptions littérales de la directive. Elles traduisent ses objectifs dans le périmètre ÉnergieAlp ; paramètres, produits, versions, durées de conservation et tolérances doivent être décidés après analyse des risques.

Sources : S1 = directive UE 2022/2555 du 14 décembre 2022 ; S2 = dossier pédagogique ÉnergieAlp, §1 à §6 ; S3 = fiches du mémo, itérations 1 et 2 ; S4 = orientation ANSSI NIS2. Références et chemins détaillés en dernière page.

# 2. Examen article par article — 1 à 16

Référence S1. Les motifs ci-dessous expliquent la sélection du périmètre. Pour H, l’absence de réglage technique ne signifie pas que l’article est sans effet juridique. État de mise en œuvre : non évalué, sauf écarts explicitement déclarés par S2.

| Art. | Objet résumé | Code | Lien au périmètre / décision motivée |
|---|---|---|---|
| 1 | Objet | H | Cadre de la directive ; aucun réglage technique isolé à en déduire. |
| 2 | Champ | A | Électricité et taille : qualification ci-dessus ; confirmer le périmètre. |
| 3 | EE / EI | A | EE proposée ; supervision art. 32 et informations d’identification art. 3 §4 à préparer selon modalités nationales. Pas de décision officielle. |
| 4 | Textes sectoriels UE | C | Rechercher équivalence sectorielle au sens du texte ; aucune exclusion établie dans le dossier. |
| 5 | Harmonisation minimale | H | Cadre pour les États ; vérifier exigences françaises additionnelles. |
| 6 | Définitions | H | Fixer vocabulaire incident, risque, entité et systèmes dans les procédures. |
| 7 | Stratégie nationale | H | Responsabilité étatique ; pas de stratégie nationale à produire par ÉnergieAlp. |
| 8 | Autorités / points de contact | H | Identifier les interlocuteurs officiels dans PR-INC ; ÉnergieAlp ne les désigne pas. |
| 9 | Gestion nationale des crises | H | Articuler l’escalade interne avec les autorités ; dispositif national hors maîtrise interne. |
| 10 | CSIRT nationaux | H | Référencer le CSIRT compétent, sans assimiler l’équipe interne à un CSIRT national. |
| 11 | Capacités / missions CSIRT | H | Obligations des CSIRT ; prévoir coopération et éléments d’incident côté entité. |
| 12 | Divulgation coordonnée | C | Prévoir réception et transmission des vulnérabilités ; mécanisme national hors entité. |
| 13 | Coopération nationale | H | Organisation des autorités ; tenir des contacts internes cohérents. |
| 14 | Groupe de coopération | H | Structure européenne ; pas de configuration ÉnergieAlp directement exigée. |
| 15 | Réseau des CSIRT | H | Coopération européenne ; contribution via le CSIRT compétent si nécessaire. |
| 16 | EU-CyCLONe | H | Coordination des crises majeures ; conserver chaîne d’escalade interne. |

# 2. Examen article par article — 17 à 31

Référence S1. Les motifs ci-dessous expliquent la sélection du périmètre. Pour H, l’absence de réglage technique ne signifie pas que l’article est sans effet juridique. État de mise en œuvre : non évalué, sauf écarts explicitement déclarés par S2.

| Art. | Objet résumé | Code | Lien au périmètre / décision motivée |
|---|---|---|---|
| 17 | Coopération internationale | H | Cadre institutionnel ; pas d’obligation technique autonome identifiée. |
| 18 | Rapport européen | H | Rapport sur l’état de la cybersécurité ; exploiter comme contexte de risque. |
| 19 | Évaluation par les pairs | H | Mécanisme institutionnel ; ne pas le confondre avec audit interne. |
| 20 | Gouvernance | A | CT-01 : politique approuvée, suivi et formation de la direction. |
| 21 | Gestion des risques | A | CT-02 à CT-13 ; décomposition §2 a à j, proportionnalité et fournisseurs. |
| 22 | Chaînes critiques | H | Évaluations coordonnées au niveau UE ; intégrer leurs résultats disponibles dans CT-06. |
| 23 | Notifications | A | CT-14 : qualification, horodatage, destinataires et délais de notification. |
| 24 | Certification | C | Rechercher une exigence imposée au périmètre concerné ; aucun certificat exigé démontré ici. |
| 25 | Normalisation | H | Utiliser les normes pertinentes comme moyens ; aucune obligation générale ISO 27001 déduite. |
| 26 | Juridiction / territorialité | A | France pour l’entité décrite ; confirmer établissement et autorités. Cloud : analyser séparément le fournisseur. |
| 27 | Registre de certaines entités | X | Activités numériques listées non décrites pour ÉnergieAlp ; utiliser un cloud ne fait pas d’elle un fournisseur cloud. |
| 28 | Données d’enregistrement DNS | X | Aucun service de registre de domaine ou d’enregistrement visé décrit. |
| 29 | Partage d’informations | C | Participation éventuelle à encadrer ; pas d’adhésion ni d’accord existant prouvé. |
| 30 | Notification volontaire | C | Circuit distinct des notifications obligatoires ; préciser les cas dans PR-INC. |
| 31 | Supervision générale | A | Préparer dossier de preuve et coopération ; encadre surtout les pouvoirs des autorités. |

# 2. Examen article par article — 32 à 46

Référence S1. Les motifs ci-dessous expliquent la sélection du périmètre. Pour H, l’absence de réglage technique ne signifie pas que l’article est sans effet juridique. État de mise en œuvre : non évalué, sauf écarts explicitement déclarés par S2.

| Art. | Objet résumé | Code | Lien au périmètre / décision motivée |
|---|---|---|---|
| 32 | Supervision EE | A | CT-15 : produire preuves et suivre demandes d’audit dans l’hypothèse EE. |
| 33 | Supervision EI | X | Non retenu avec hypothèse EE ; réexaminer si qualification modifiée. |
| 34 | Amendes administratives | A | Prendre en compte gouvernance et risque juridique ; pas d’amende effective déduite du dossier. |
| 35 | Articulation RGPD | C | Articuler incident cyber et violation personnelle ; ne pas confondre notifications NIS2/RGPD. |
| 36 | Sanctions nationales | H | Règles à établir par les États ; vérifier droit national avant chiffrage opérationnel. |
| 37 | Assistance mutuelle | H | Coopération entre autorités ; centraliser réponses et demandes côté entité. |
| 38 | Délégation | H | Pouvoirs de la Commission ; aucune configuration directement applicable. |
| 39 | Comité | H | Procédure institutionnelle ; aucune action technique interne autonome. |
| 40 | Réexamen | H | Suivre évolution du texte dans la veille juridique. |
| 41 | Transposition | H | Vérifier les textes nationaux et leurs dates ; la directive seule ne décrit pas toutes les modalités françaises. |
| 42 | Modification UE 910/2014 | H | Articulation des textes ; pas de service de confiance décrit pour ÉnergieAlp. |
| 43 | Modification UE 2018/1972 | H | Articulation communications électroniques ; aucune activité de fournisseur décrite. |
| 44 | Abrogation NIS1 | H | Distinguer ancien statut OSE et qualification EE/EI ; ne pas les confondre. |
| 45 | Entrée en vigueur | H | Repère temporel européen ; ne vaut pas preuve de mise en œuvre nationale. |
| 46 | Destinataires | H | Directive adressée aux États membres ; exigences opérationnelles à lire avec transposition. |

# 3. Gouvernance et cadre des configurations

| ID / base | Exigence et applicabilité | Cible proposée / contrôle | Preuve et état | Pilote / action |
|---|---|---|---|---|
| CT-01<br>Art. 20 §1–2 | Hypothèse EE : direction responsable de l’approbation et de la supervision des mesures ; formation. | Faire approuver PSSI, responsables, budget et tableau de suivi. Inclure formation de la direction et dispositif de formation des équipes. Contrôle : décisions et suivi des écarts. | PR-01 : PSSI signée, PV, suivi, attestations. Non documenté dans S2 ; aucune adoption démontrée. | Direction, coordination RSSI proposée. Vérifier l’existant et proposer validation à J+30. |
| CT-02<br>Art. 21 §1, §2 a | Hypothèse EE : analyse proportionnée des risques, tous risques, y compris environnement physique. | Relier chaque EA à impacts, menaces, dépendances, risque et traitement. Examiner énergie, locaux, télécoms et accès physiques. Contrôle : échantillon de risques reliés aux actifs. | PR-02 : analyse et décisions datées. Risque cloud non formalisé selon S2 ; autres analyses non documentées. | RSSI, DSI et Production. Prioriser cloud et accès supervision ; lancer à J+7. |
| CT-06b<br>Art. 21 §3 | Fournisseurs directs : tenir compte des vulnérabilités, qualité et pratiques de sécurité. | Évaluer GridSoft, CloudPeak et RéseauTech ; exiger preuves proportionnées, gestion des vulnérabilités et conditions d’accès. Contrôle : revue des trois dossiers. | PR-06 : évaluations, engagements et risques résiduels. Contrat CloudPeak absent dans S2 ; autres contrats non décrits. | DSI / Production, RSSI et juridique proposés ; PR-ST-01/02. |
| CT-16<br>Art. 21 §4 | Corriger sans retard indu les non-conformités constatées aux mesures retenues. | Ouvrir un ticket par écart, responsable et cible ; tester correction, enregistrer preuve, arbitrer risques résiduels. Contrôle : empêcher clôture sans vérification. | PR-16 : registre d’écarts, tickets et recontrôles. Document préparé ; aucun ticket réel ni correction attestés. | RSSI pour suivi ; DSI/Production exécutants. Délais proposés en plan de remédiation. |

Art. 21 §5 : suivre les actes d’exécution pertinents ; le règlement UE 2024/2690 cible certaines catégories de fournisseurs numériques. Le seul recours à CloudPeak n’établit pas son applicabilité directe à ÉnergieAlp. Les réglages détaillés retenus ci-après sont des propositions locales, à proportionner au risque.

J = date future d’approbation du plan. Les échéances ne sont pas des dates légales. Toute modification touchant supervision ou SI clientèle passe par une fenêtre validée, essais et retour arrière ; RSSI seul pour une dérogation de sécurité.

# 4. Matrice technique — article 21 §2, b à e

Chaque ligne est applicable dans l’hypothèse EE. Les cibles et tests sont proposés, sans exécution. Les constats reposent exclusivement sur S2 ; CT-02 couvre le point a.

| ID / article | Périmètre | Configuration / dispositif cible | Test de contrôle attendu | Preuve / situation connue | Responsable proposé |
|---|---|---|---|---|---|
| CT-03<br>21 §2 b | Incidents — tous EA | Centraliser alertes et traces utiles avec source, compte, action, résultat et horodatage fiable ; définir triage et escalade. | Injecter un événement de test autorisé ; vérifier collecte, qualification et ticket sans prétendre simuler une attaque réelle. | PR-03 : événement brut, ticket, chronologie et revue. Journaux VPN mentionnés ; couverture/collecte non documentées. | RSSI / DSI, Production pour EA-01. |
| CT-04<br>21 §2 c | Continuité — EA-01/03 prioritaires | Définir objectifs de reprise et perte de données avec métiers ; sauvegardes séparées, accès limités et procédure de restauration ; solution de continuité adaptée à l’actif. | Restaurer un échantillon isolé ; contrôler données et service, mesurer délai et perte ; tester scénario de crise. | PR-04 : politique, test de restauration et décision métier. Sauvegardes et reprise non documentées. | DSI / Production. Aucune tolérance inventée comme validée. |
| CT-05<br>21 §2 c | Gestion de crise — tous EA | Définir cellule de crise, suppléants, annuaire protégé et accessible en cas de panne ; modes dégradés et règles de décision. | Exercice sur table : indisponibilité VPN ou cloud ; vérifier mobilisation, communication et décisions sans action sur production. | PR-05 : procédure et compte rendu d’exercice identifié comme simulé. Dispositif existant non documenté. | Direction, RSSI, DSI et Production ; rôles proposés. |
| CT-06<br>21 §2 d | Fournisseurs — ST-01/02/03 | Comptes nominatifs de tiers, périmètre et durée approuvés, clauses incident/accès/réversibilité ; revue des responsabilités cloud. | Comparer comptes et contrats aux missions approuvées ; tester expiration et retrait sans interrompre la production. | PR-06 : contrats, habilitations, revues. Écarts déclarés : cloud sans contrat ; accès tiers sans revue documentée. | DSI / Production ; PR-ST-01 à 04. |
| CT-07<br>21 §2 e | Acquisition et maintenance — tous EA | Inventorier versions/support ; qualifier avis et correctifs ; paramètres de durcissement adaptés au produit ; canal de réception des vulnérabilités. | Sur environnement de test, appliquer un changement approuvé, vérifier service et retour arrière avant fenêtre de production. | PR-07 : inventaire versions, avis, tests et journal de changement. Versions, support et durcissement non fournis. | DSI / Production ; GridSoft consulté pour EA-01. |

# 5. Matrice technique — article 21 §2, f à j

| ID / article | Périmètre | Configuration / dispositif cible | Test de contrôle attendu | Preuve / situation connue | Responsable proposé |
|---|---|---|---|---|---|
| CT-08<br>21 §2 f | Tous EA | Planifier contrôles d’efficacité ; suivi des écarts et conservation protégée des résultats. | Échantillonner comptes, restaurations et correctifs ; rapprocher résultats des objectifs et décider actions. | PR-08 : plan, rapports et recontrôles. Aucun résultat fourni. | RSSI ; DSI / Production. |
| CT-09<br>21 §2 g | Personnel et tiers | Socle d’hygiène et formation selon rôles : comptes, accès distant, données et signalement ; suivi des habilitations. | Vérifier parcours d’accueil et évaluations ; exercice de signalement maîtrisé. | PR-09 : supports, présence et évaluation. Formation non documentée. | RSSI ; RH proposée. |
| CT-10<br>21 §2 h | EA-03/04/05 ; autres selon risque | Chiffrer flux et données sensibles selon analyse ; gérer certificats, accès aux clés, rotation et récupération ; paramètres à définir après inventaire. | Vérifier protocole/certificat réellement négocié et accès aux clés ; tester récupération sur copie isolée. | PR-10 : politique, export anonymisé, tests. Aucun protocole, algorithme ou clé observé. | DSI ; RSSI pour politique. |
| CT-11<br>21 §2 i | EA-01 à EA-05 | Registre avec propriétaire, données, dépendances, criticité, version et cycle de vie ; revue après changement et périodique. | Rapprocher registre, terrain, cloud et inventaire existant ; justifier exclusions. | PR-11 : registre réconcilié et validé. Registre incomplet selon S2 ; V0 produite ici. | DSI / Production. |
| CT-12<br>21 §2 i | Comptes internes et tiers | Moindre privilège ; comptes nominatifs, séparation administration/usages, expiration des accès tiers et retrait après départ ; revue proposée trimestrielle. | Tester refus hors périmètre, compte expiré et retrait ; vérifier attribution des actions sur systèmes cibles. | PR-12 : matrice de droits, exports et revues. Accès tiers sans stratégie ni revue documentée. | DSI / Production ; RH pour mouvements, rôle proposé. |
| CT-13<br>21 §2 j | EA-05 vers EA-01 | MFA sur accès VPN sensibles, exceptions identifiées et approuvées ; aucun accès tiers partagé ; prévoir moyens de communication de crise adaptés. | Tester connexion avec facteur, refus sans facteur/invalide, secours contrôlé et continuité ; ne pas supprimer accès avant solution validée. | PR-13 : paramètres et essais. VPN sans MFA établi par S2 ; communications de crise non décrites. | DSI, Production et RSSI. |

# 6. Notification, supervision et contrôles associés

| ID / base | Applicabilité / résultat attendu | Traduction technique et organisationnelle | Contrôle / preuve attendue | État et pilote |
|---|---|---|---|---|
| CT-14<br>Art. 23 §1–4 | Hypothèse EE ; traiter les incidents significatifs selon critères du texte, pas tout événement technique. | PR-INC proposée : horodater prise de connaissance, qualifier gravité/impact, informer RSSI/direction, identifier CSIRT/autorité et canal national ; journal des décisions protégé. | PR-14 : chronologie, qualification, projet de notification et accusé de réception si envoi réel. Exercice étiqueté simulation ; aucun envoi externe effectué ici. | Procédure existante non documentée. RSSI pilote proposé, DSI/Production contributeurs. |
| CT-14a<br>Art. 23 §4 | Sans retard injustifié ; repères européens de notification. | Alerte précoce sous 24 h après prise de connaissance ; notification sous 72 h ; mises à jour et rapport intermédiaire sur demande ; rapport final au plus tard un mois après notification. Si incident en cours : rapport d’avancement puis final après traitement selon texte. | Exercice : T0 horodaté, échéances calculées, destinataires vérifiés et validation sans attendre l’enquête complète. Cas particuliers à vérifier ; aucun service de confiance décrit. | Aucun délai réellement mesuré. Articuler avec RGPD 33–34 si données personnelles ; circuits et critères distincts. |
| CT-15<br>Art. 31–32 | Hypothèse EE ; coopération avec supervision et demandes légitimes. | Dépôt de preuve à accès contrôlé ; index source–contrôle–actif–preuve–date ; accès en lecture et journal des remises. Vérifier habilitation et périmètre de la demande. | PR-15 : index, habilitations, export anonymisé, bordereau de remise et suivi des mesures correctrices. | Dossier documentaire préparé ; aucun contrôle d’autorité attesté. RSSI/direction proposés. |
| JUR-01<br>Art. 3 §4, 26, 27–30 | Art. 3 §4 : informations d’identification requises selon modalités nationales. Art. 26 : France ; 27–28 hors activité décrite ; 29–30 conditionnels. | Préparer identité, adresse, secteur et contacts ; vérifier transmission à l’autorité et mises à jour. Vérifier établissement et interlocuteurs. Si partage volontaire : accord, classification, destinataires et données minimales ; séparer du circuit obligatoire art. 23. | Décision juridique documentée ; accord de partage seulement si choisi. Aucune inscription à un registre réservé aux fournisseurs numériques déduite de l’usage du cloud. | Non évalué ; RSSI et appui juridique proposé. |
| JUR-02<br>Art. 34–35 | Prendre en compte sanctions et articulation RGPD. | Pas de configuration directe. Intégrer risque de sanction à la gouvernance ; ne pas additionner mécaniquement sanctions pour un même comportement. | Analyse juridique au cas par cas. Art. 34 : maxima nationaux au moins 10 M€ ou 2 % pour EE, 7 M€ ou 1,4 % pour EI, montant supérieur retenu. | Aucune sanction ni violation juridique réelle établie ; droit national à vérifier. |

# 7. Registre des actifs critiques — V0

Source S2, §2–5. Notes proposées de 1 faible à 4 critique. C = confidentialité ; I = intégrité ; D = disponibilité ; T = traçabilité. Globale = maximum(C,I,D,T). Les notes expriment les besoins métier, sans mesurer les protections existantes. D4 signifie besoin de continuité ; il ne prouve pas une disponibilité réelle de 100 %.

| Actif / données | Responsable et dépendances connues | C/I/D/T → max | Justification des quatre notes / réserve |
|---|---|---|---|
| EA-01 SCADA<br>États, mesures, commandes | Responsable Production ; GridSoft ; accès distant via EA-05. | 3/4/4/4 → 4 | C3 : équipes habilitées. I4 : commandes/états altérés affectent exploitation. D4 : continuité explicitement exigée. T4 : attribuer commandes et interventions. Impact détaillé à confirmer, sans approfondissement industriel. |
| EA-02 Compteurs<br>Consommation, identifiant, adresse | Responsable métier à désigner ; Production proposée ; maintenance RéseauTech. | 3/3/3/3 → 3 | C3 : relevés rattachables aux clients. I3 : relevés erronés affectent usages SI. D3 : tolérance de relève jusqu'à 24 h proposée. T3 : accès et changements administratifs. Panne de relève ≠ coupure électrique. |
| EA-03 CRM/facturation<br>Identité, adresse, IBAN, historique | DSI ; CloudPeak pour une partie de l'hébergement. | 4/4/4/4 → 4 | C4 : habilitations nominatives sur données clients/IBAN. I4 : contrats/factures altérés à grande échelle. D4 : continuité clientèle exigée. T4 : retracer accès et modifications. Droits et journaux réels non fournis. |
| EA-04 Analytics<br>Consommation agrégée et individuelle | DSI ; hébergement CloudPeak. | 3/4/3/3 → 4 | C3 : données individuelles restreintes. I4 : prévisions erronées peuvent dégrader décisions de charge, hypothèse prudente. D3 : 24 h proposées. T3 : traitements et administration attribuables. Dépendance réelle des décisions à confirmer. |
| EA-05 VPN<br>Identifiants et journaux de connexion | DSI ; techniciens et RéseauTech ; accès à EA-01. | 4/4/3/4 → 4 | C4 : secrets individuels. I4 : droits/configuration altérés ouvrent un accès indu. D3 : accès distant bloqué, 24 h proposées à confirmer. T4 : connexions et actions privilégiées. Les traces VPN seules ne prouvent pas les actions SCADA. |

Échelle retenue : C1 public / C2 interne / C3 services habilités / C4 personnes explicitement autorisées ; I1 impact négligeable / I2 limité / I3 important / I4 majeur ; D1 >7 jours / D2 >24 h à 7 jours / D3 jusqu'à 24 h / D4 aucune interruption acceptable ; T1 aucun besoin particulier / T2 utilisateurs / T3 administrateurs en complément / T4 ensemble des actions.

Adaptation pédagogique : l'échelle d'intégrité du kit mélange fréquence de revue et impact ; les intervalles de disponibilité ont été explicités. À discuter au débrief. Compléter par instances, versions, emplacements, cycle de vie, date et validateur. Vérifier terrain (postes/disjoncteurs), identité, réseau, sauvegardes et collecte des traces : non décrits en détail, sans présumer leur absence. Le registre existant n'étant pas fourni, les actifs qui y manquent ne sont pas identifiables.

# 8. Registre des sous-traitants et prestataires

Ces relations sont décrites dans S2 §3–4. Le qualificatif « sous-traitant RGPD » et les rôles juridiques exacts restent à vérifier selon les traitements ; la gestion de la chaîne d'approvisionnement NIS2 ne se limite pas au RGPD.

| ID / prestataire | Actifs / service | Situation connue et incertitudes | Exigences proposées / preuve attendue | Responsable interne |
|---|---|---|---|---|
| ST-01<br>GridSoft Solutions<br>France | EA-01 ; éditeur et intégrateur SCADA. | Accès fourni à la demande, sans stratégie ni revue périodique documentée. Canal d'accès, droits, contrats, versions et engagements non fournis ; ne pas présumer un accès VPN GridSoft. | PR-ST-01/02 : mission, périmètre, interlocuteurs, engagements sécurité/incident/vulnérabilités ; PR-ST-03 : comptes autorisés et traçabilité ; PR-ST-04 : retrait. Preuves PR-06/12. | Responsable Production ; coordination DSI/RSSI proposée. |
| ST-02<br>CloudPeak Americas<br>Filiale européenne d'un groupe américain | EA-03 partiel et EA-04 ; cloud public. | Aucun contrat mis en place et aucune analyse de risque documentée formalisée. Région, entité contractante, clés, sous-prestataires et réversibilité inconnus. Aucun transfert US ni accès étatique établi. | PR-ST-01/02 : analyse juridiction/contrôle/localisation, responsabilités partagées, accès, incident, sauvegarde, réversibilité ; clauses RGPD art. 28 et transferts si pertinents. Contrat et analyse approuvés, tests de sortie/restauration attendus. | DSI ; RSSI et juridique proposés pour risque/contrat. |
| ST-03<br>RéseauTech Maintenance<br>France, PME régionale | EA-02 et équipements terrain ; accès VPN EA-05 vers supervision EA-01. | VPN sans MFA ; accès à la demande sans stratégie ni revue périodique documentée. Comptes, droits détaillés et durée d'accès inconnus. | PR-ST-03 : compte nominatif, MFA, droits limités à mission, expiration et fenêtre ; corréler connexions et interventions ; PR-ST-04 : retrait et preuve. Aucun secret à joindre au dossier. | Production pour terrain/supervision ; DSI pour VPN. |

Tenue du registre proposée : identifiant stable, contrat et version, actifs/données accessibles, responsable interne, contacts d'incident, sous-prestataires, date d'évaluation, risque résiduel, prochaine revue et date de fin. Révision à chaque changement de mission, d'hébergement ou de droits ; revue périodique proposée trimestrielle pour les accès et annuelle pour le dossier fournisseur, à valider selon le risque.

# 9. Procédures proposées de gestion des tiers

| Procédure / déclencheur | Responsable et déroulement proposé | Condition de contrôle / preuve |
|---|---|---|
| PR-ST-01<br>Avant sélection, renouvellement ou changement de périmètre | DSI ou Production recense service, données, actifs, accès et dépendances ; RSSI évalue criticité et risques, collecte engagements de sécurité et pratiques de traitement des vulnérabilités ; appui juridique examine juridiction et transferts éventuels. | Fiche fournisseur complète, risque motivé, questions ouvertes et décision approuvée. Refuser la clôture de l'évaluation si responsable, périmètre ou risque résiduel restent sans arbitrage. |
| PR-ST-02<br>Avant ouverture du service / régularisation cloud | Responsable interne formalise responsabilités partagées, droits d'audit proportionnés, incidents, vulnérabilités, continuité, réversibilité et sous-prestataires. Juridique proposé pour contrat et RGPD. RSSI examine garanties et écarts. | Contrat signé et annexes reliés à ST/EA ; décision documentée sur écarts. Situation CloudPeak à régulariser sans interruption non préparée. Une dérogation RSSI ne remplace pas un contrat ou une obligation légale. |
| PR-ST-03<br>Chaque demande d'accès et revue périodique | Demande identifie personne, mission, actifs, droits, début/fin et fenêtre. Responsable du système approuve ; DSI configure compte nominatif/MFA/droits/expiration. Production valide impact supervision. Contrôler traces utiles sans exposer de secrets. Revue trimestrielle proposée et après changement de mission. | Test connexion autorisée, refus hors périmètre et expiration ; export anonymisé, approbation, revue et décisions de retrait. Journal VPN à rapprocher des actions sur cible si disponibles. Exception de sécurité : RSSI seul, motif, mesures compensatoires et fin définie. |
| PR-ST-04<br>Fin de mission, incident ou fin de contrat | Responsable interne déclenche retrait ; DSI désactive comptes, sessions et accès, traite secrets partagés s'ils existent ; Production coordonne terrain. À la sortie : récupérer données/configurations selon contrat, vérifier reprise, puis effacement selon obligations de conservation. Incident : activer PR-INC et préserver traces. | Test d'accès refusé après retrait, inventaire des accès clos et données restituées, procès-verbal de sortie et attestation d'effacement si pertinente. Tester réversibilité avant dépendance définitive au fournisseur. |

Statut des quatre procédures : rédigées comme propositions documentaires pour le scénario. Aucun contrat signé, compte créé/révoqué, contrôle d'expiration ni revue réellement exécutée n'est attesté. Approbation, diffusion, essai et preuve d'application restent nécessaires pour démontrer la mise en œuvre.

# 10. Plan d’action et index des preuves

| Priorité / délai proposé | Écart ou point à vérifier | Action et pilote | Critère de clôture |
|---|---|---|---|
| P1 • J+7 étude | VPN sans MFA — CT-13 | DSI et Production : compatibilité, scénario de secours et planification ; RSSI pour risques. | Essais avec/sans second facteur et continuité, preuve PR-13 ; déploiement seulement en fenêtre validée. |
| P1 • J+7 lancement | Cloud sans contrat/analyse — CT-02/06 | DSI, RSSI, juridique proposé : analyse, responsabilités et engagements. | Analyse approuvée, décision de risque et contrat ; questions localisation/accès traitées. |
| P1 • J+15 première revue | Accès tiers sans revue — CT-12 | DSI et Production : rapprocher missions/comptes, faire approuver puis retirer droits inutiles. | Revue datée, droits justifiés, expiration et tests de retrait. |
| P1 • J+30 | Registre incomplet — CT-11 | DSI et Production : comparer V0 à inventaire, terrain et cloud ; validation métier. | Actifs rapprochés, dépendances et cotations justifiées ; exclusions tracées. |
| P2 • J+30 vérification | Gouvernance, reprise, traces, notifications non documentées | RSSI, direction, DSI et Production : demander preuves existantes et planifier essais manquants. | Décision fondée sur preuves ou plan daté pour les lacunes ; aucune absence réelle déduite du silence du dossier. |

Index : P-DOS-01 = dossier pédagogique ÉnergieAlp §1–6, producteur non nommé, date source non fournie ; lecture documentaire du 15/10/2026. Il établit les faits du scénario et leurs limites, sans attester une inspection réelle. DOC-01 = présent PDF et source Markdown ; DOC-02 = registre V0 du mémo ; DOC-03 = procédures PR-ST-01 à 04 incluses ici. Ce sont des productions documentaires disponibles.

PR-01 à PR-16 = emplacements logiques des futures preuves des contrôles portant le même numéro ; pas de pièces techniques collectées à ce stade. CT-06b partage PR-06. Les références non utilisées ne désignent aucune preuve existante.

| Métadonnée requise pour chaque future preuve | Valeur à conserver |
|---|---|
| Identification et collecte | ID PR, contrôle CT, actif EA, fournisseur ST si pertinent ; producteur/collecteur nommé ; date, heure et fuseau ; période couverte. |
| Origine, méthode et résultat | Système/version, configuration effectivement chargée, comptes/échantillon ; export ou protocole de test ; attendu/constaté ; limites et conclusion. |
| Conservation et validation | Original dans espace contrôlé, version/empreinte si utile, droits et durée de conservation décidés ; copie anonymisée pour présentation ; relecteur et date. |

# 11. Bilan de preuve et références

| Critère du formateur | Travail produit | Éléments restant à démontrer |
|---|---|---|
| Matrice article par article | 46 articles examinés ; décisions d’applicabilité et motifs. Art. 21 décomposé ; configurations et contrôles reliés aux actifs. | Qualification confirmée sur périmètre juridique ; vérification du droit français et des modalités applicables. |
| Lien obligations / configurations | CT-01 à CT-16 et CT-06b ; objectifs, paramètres cibles, tests et références de preuve. | Exports réels, tests datés, comportement constaté et traitement des écarts ; aucune efficacité opérationnelle démontrée. |
| Registre des actifs critiques | Cinq services identifiés, responsables connus ou proposés, dépendances, C/I/D/T justifiés et réserves. | Inventaire existant réconcilié, instances/versions/sites, actifs de support et validation métier. |
| Gestion des sous-traitants | Trois prestataires recensés et quatre procédures : qualification, contractualisation, accès/revue, incident/sortie. | Approbation, contrats, évaluations, revues et preuves d’application. |

Conclusion de portée : ce livrable étaye la participation à l’élaboration de la politique de sécurité par un travail de qualification, de formalisation et de préparation des contrôles. Il ne suffit pas à démontrer leur mise en œuvre. Aucune conformité globale, certification, approbation du formateur ou exécution réelle n’est revendiquée.

Références consultées le 15 octobre 2026 ; reformulations pédagogiques, sans reproduction extensive du texte légal :

S1 — Directive (UE) 2022/2555, articles 1–46 et annexe I : https://eur-lex.europa.eu/eli/dir/2022/2555/oj

S4 — ANSSI, directive NIS2 : https://cyber.gouv.fr/reglementation/cybersecurite-systemes-dinformation/directives-nis-nis2-et-dispositif-saiv/directive-nis-2/

Orientation de qualification : https://messervices.cyber.gouv.fr/conseils-cyber/directive-nis2-mon-organisation-est-elle-concernee

RGPD (articulation cloud et incidents) : https://www.cnil.fr/fr/reglement-europeen-protection-donnees

S2 — Source locale : docs/droit-conformite/annexes/dossier-entreprise-energiealp.md, §1 à §6.

S3 — Analyse initiale : docs/droit-conformite/it-1/de-exigence-a-preuve.md et comprendre-conformite-reglementaire.md ; registre : docs/droit-conformite/it-2/registre-actifs-critiques.md.

Pour le débrief : confirmer les décisions d’applicabilité, les cotations provisoires (notamment EA-04 I4 et les D3), les pilotes et les échéances ; identifier les preuves opérationnelles attendues avant d’attribuer un état de conformité.